

Cisco Secure Workload - NIST SP 800-82 Compliance Report

Cisco Secure Workload - NIST SP 800-82 Compliance Report

Customer-Facing Compliance Report

Framework: NIST SP 800-82 Revision 3 - Guide to Operational Technology (OT) Security (September 2023)

Primary audience: Industrial / critical-infrastructure operators (manufacturing, energy, water, transportation, pharma, food production) and any organisation with an OT estate whose IT-side boundary must demonstrate segmentation hygiene.

CSW positioning: IT-side segmentation adjacent to OT zones; the OT device layer is addressed by an OT-native product (Cyber Vision, Claroty, Nozomi). CSW focuses on the IT-side workloads (historians, engineering workstations, jump hosts, IT/OT DMZ, monitoring, patch / asset servers).

Framework Version Note

NIST SP 800-82 Rev. 3 is guidance, not a separate control catalogue. It uses NIST SP 800-53 Rev. 5 as its underlying control framework and provides an OT-tailored overlay. This report references 800-82 topic areas and the 800-53 control families they align to; the customer's OT cybersecurity programme determines the actual control tailoring.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-NIST-800-82-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

NIST-800-82

├─ OT-Adjacent-IT (Historians, Patch-Servers-OT-Direction,
Engineering-Workstations, Jump-Hosts-to-OT)
├─ OT-Monitoring-IT-Side
├─ Enterprise-IT
└─ OT-Zones (NOT instrumented by CSW; observed via flow visibility only)

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Network architecture and segmentation (IT side of the IT/OT boundary) - 800-53 SC-7, AC-4
- Monitoring (IT side) - 800-53 SI-4, AU family
- Access control (workload-to-workload, IT side) - 800-53 AC-3, AC-4, AC-6
- Vulnerability management (reachability-weighted, OT-aware) - 800-53 RA-5, SI-2
- Incident response (IT-side forensic input) - 800-53 IR family
- Configuration / change management (IT-side workspace baseline) - 800-53 CM family

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- OT device-layer policy and protocol inspection (use an OT-native product)
- OT change management and OT-side cybersecurity programme governance
- Identity management and physical security

- Cryptography for OT protocols
- BCP/DR for OT operations

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Network architecture / segmentation (IT side)	Direct	Policy workspace; observed IT-OT flows; ADM-derived allowlist	Workspace snapshot + observed IT-OT flow report
Monitoring (IT side)	Direct	Continuous flow / process telemetry; alerts on unauthorised IT-OT flow	Alert and anomaly log scoped to OT-Adjacent-IT
Access control (IT side)	Direct	Workload-to-workload allowlist + enforcement log	Workspace snapshot and violation/exception register
Vulnerability management (OT-aware)	Direct	Reachability-weighted CVE on OT-adjacent IT workloads	Prioritised remediation list with compensating-control register
Incident response (IT side)	Direct	Forensic flow / process search across the incident window	Investigation pack with timeline and impact scope
Configuration management	Direct	Workspace snapshot before/after each change	Change-controlled policy workspace export

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
OT-adjacent IT inventory	Workloads adjacent to OT zones with isa_level and it_or_ot labels	Inventory + scope membership export	Monthly
IT-OT boundary flow evidence	Approved vs. observed IT-OT flow comparison	ADM workspace export + policy workspace export	Quarterly
Jump-host activity	Jump-host flows to OT-Zones with	Flow search on	Continuous; reviewed

Topic	What to collect	CSW source	Suggested cadence
	timing	Jump-Hosts-to-OT	monthly
Vulnerability + reachability	CVE list weighted by reach into OT-Zones	Vulnerability report scoped to NIST-800-82	Monthly
Incident sample (IT side)	One representative IT-side incident timeline	Flow + process search	Per incident; one representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not enforce policy on OT devices, parse OT protocols (Modbus, DNP3, S7, OPC UA, etc.), manage OT change windows, replace an OT-native product (Cyber Vision, Claroty, Nozomi), or replace the OT cybersecurity programme.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.